

E-Commerce Data Breach Investigation

Simulated end-to-end incident report: alert, scope, timeline, containment, root cause, and corrective actions

Executive Summary

A simulated e-commerce application showed evidence of unauthorized access to a customer-data export function after exploitation of an outdated web component. The case is synthetic and uses example indicators. The investigation demonstrates incident scoping and response methodology rather than a claim of a real breach.

Field	Assessment
Incident ID	IR-2026-004
Severity	SEV-1 / Critical
Category	Unauthorized access / potential data exposure
Affected service	Customer account portal
Initial access	Simulated exploitation of outdated internet-facing component
Potentially affected data	Customer contact and order-history records
Confirmed exposure	Limited synthetic dataset accessed in the scenario
Attribution	Not determined
Status	Contained; corrective actions tracked

Timeline

Time	Event
09:12	WAF/SIEM generated anomaly for repeated requests to a vulnerable application path.
09:18	Analyst correlated unusual requests with new outbound application behavior.
09:27	Application logs showed access to an export endpoint outside normal workflow.
09:35	SEV-1 declared due to possible customer-data exposure.
09:42	Affected application instance removed from service; credentials/tokens rotated.
10:05	Vulnerable component version confirmed in simulated inventory.
10:24	Patch/rebuild path initiated; logs and relevant evidence preserved.
11:10	No additional unauthorized sessions observed after containment.
13:30	Rebuilt service passed validation and monitoring checks.
Next day	Post-incident review initiated; long-term corrective actions assigned.

Evidence & IOC Register

ID	Evidence	Finding	Disposition
E-401	WAF event set	Repeated abnormal requests to vulnerable path	Preserved; used for initial-access timeline
E-402	Application access logs	Unexpected export endpoint access	Preserved; used for scope
E-403	Auth logs	Session associated with unauthorized activity	Token revoked; logs retained
E-404	Example IP 198.51.100.24	Synthetic external source indicator	Blocked in scenario; not treated as real-world malicious intelligence
E-405	Rebuild validation results	Patched version and normal monitoring behavior	Closure evidence

Root Cause & Contributing Factors

- **Primary root cause:** A simulated internet-facing component was not remediated within the intended vulnerability-management window.
- **Contributing factor:** Asset/version visibility was incomplete, delaying ownership and patch accountability.
- **Contributing factor:** Export activity was logged but not originally tied to a high-confidence detection use case.
- **Contributing factor:** Service credentials had broader access than needed.

MITRE ATT&CK; Mapping

Behavior	Mapping	Analyst note
Initial exploitation of public application	Initial Access concept	Exact ATT&CK; technique depends on the exploited vulnerability and evidence; no unsupported technique ID is asserted.
Use of valid application session after access	Valid-account/session concept	Session evidence supports authenticated follow-on activity, but attribution is not established.
Account enumeration during post-compromise activity	T1087 - Account Discovery	Mapped when account-listing behavior is observed.
PowerShell on affected Windows admin host	T1059.001 - PowerShell	Mapped only if host evidence confirms PowerShell execution.

Corrective Actions

- Define critical vulnerability remediation SLA and escalation for internet-facing assets.
- Maintain ownership and version inventory for exposed applications and dependencies.
- Reduce service-account permissions to minimum required access.
- Alert on unusual bulk exports and sensitive administrative actions.
- Require centralized retention of WAF, application, authentication, endpoint, and cloud logs.
- Test incident procedures with data-exposure tabletop scenarios.
- Track remediation through validation, not ticket closure alone.